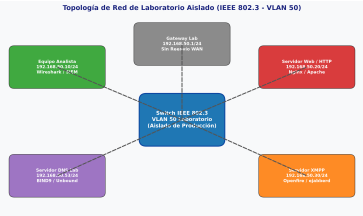
UNIVERSIDAD DISTRITAL FRANCISCO JOSÉ DE CALDAS

FACULTAD DE INGENIERÍA

PROYECTO CURRICULAR DE INGENIERÍA DE SISTEMAS



INFORME TÉCNICO DE LABORATORIO

GUÍA–TALLER No. 2

Mecanismos de Seguridad para Redes IEEE 802.3 con Servidores TCP/IP y Sistema de Rastreo Inteligente con IA

Estudiantes Investigadores:
Grupo de Investigación y Ciberseguridad
Ingeniería de Sistemas - Redes
Universidad Distrital FJDC

Docente Titular:
Ing. Octavio José Salcedo Parra
Fundamentos de Redes de Comunicaciones
Mecanismos de Seguridad Informática

Bogotá D.C., Colombia
Noviembre 14 / 2026

Índice

1. Resumen Ejecutivo y Alcance del Laboratorio **2**
1.1. Diferenciación Epistemológica en la Investigación de Incidentes . . . 2
1.2. Topología del Laboratorio Aislado y Reglas de Trabajo . . . 2
1.3. Cadena de Custodia Criptográfica de Evidencias (SHA-256) . . . 3

2. Parte I: Desarrollo de Casos Críticos de Seguridad de Red **4**
2.1. Caso 1: TCP SYN Flood: Indisponibilidad y Agotamiento de Conexiones . . . 4
2.2. Caso 2: DNS Tunneling: Salida Encubierta mediante UDP/53 . . . 6
2.3. Caso 3: Exposición de Servicios HTTP, FTP y Otros Servicios Heredados . . . 8
2.4. Caso 4: Detección de Anomalías con IA/ML en Tráfico TCP/IP . . . 10
2.5. Caso 5: TCP: Resets Inesperados e Indicios de Inyección o Desincronización . . . 12
2.6. Caso 6: UDP: Reflexión / Amplificación DNS, NTP o SSDP . . . 14
2.7. Caso 7: ICMP: Escaneo, Payloads Atípicos y Posible Túnel . . . 16
2.8. Caso 8: Escaneo de Puertos y Fingerprinting de Servicios . . . 18
2.9. Caso 9: Priorización y Correlación de Alertas con IA y SIEM . . . 20
2.10. Caso 10: Mensajería XMPP: Interceptación y Errores de TLS . . . 22

3. Parte II: Sistema Inteligente de Rastreo Ético, Geofencing y Detección de Anomalías **24**
3.1. Explicación Técnica y Viabilidad de Rastreo por Canal . . . 24
3.2. Arquitectura del Sistema de Software Desarrollado . . . 24
3.3. Modelado Matemático de Geofencing y Detección Cinemática . . . 25
3.4. Resultados y Evidencias del Sistema en Operación . . . 26
3.5. Marco Ético, Jurídico y de Seguridad Informática . . . 27

4. Conclusiones, Límites de la Evidencia y Plan de Mejora **28**
4.1. Conclusiones Técnicas . . . 28
4.2. Límites Epistemológicos de la Evidencia Digital . . . 28
4.3. Plan de Mejora Priorizado para la Infraestructura . . . 28

1. Resumen Ejecutivo y Alcance del Laboratorio

El presente informe consolida el desarrollo integral de la **Guía–Taller No. 2**, orientada a la identificación, análisis forense, mitigación y contención de riesgos sobre la disponibilidad, confidencialidad e integridad en arquitecturas de red de área local Ethernet **IEEE 802.3** que transportan protocolos de la pila **TCP/IP** (IPv4/IPv6).

El laboratorio se estructura en dos componentes complementarios:

1. **Parte I: Análisis Forense y Defensivo de 10 Casos Críticos de Red:** Evaluación exhaustiva de ataques de agotamiento de recursos (TCP SYN Flood), canales encubiertos y exfiltración (DNS e ICMP Tunneling), exposición de servicios obsoletos en texto claro (HTTP/FTP/Telnet), inyecciones de control (TCP Resets desincronizados), amplificación volumétrica UDP (DNS/NTP/SSDP), escaneo sigiloso y fingerprinting, culminando con la priorización y correlación multicapa asistida por Inteligencia Artificial (SIEM/ML) y la auditoría criptográfica de mensajería XMPP con TLS.

2. **Parte II: Desarrollo de Sistema Inteligente de Rastreo Ético y Geofencing:** Diseño e implementación de una plataforma completa de software (Backend REST en FastAPI, Base de Datos SQLite, Frontend interactivo con mapas Leaflet.js, Bot interactivo de mensajería en Telegram y Motor de Machine Learning Cinemático) orientada a la localización consentida de terminales, delimitación de geocercas y detección heurística de anomalías espaciotemporales (anti-spoofing).

1.1. Diferenciación Epistemológica en la Investigación de Incidentes

Conforme a los lineamientos pedagógicos del laboratorio, el equipo analista mantiene una rigurosa separación entre las fases de investigación técnica:

- **Síntoma:** Manifestación fenomenológica superficial u operativa observable en el sistema (ej. degradación en el tiempo de respuesta del servidor web, latencia inusual en consultas DNS o reinicios esporádicos de conexión).

- **Indicador de Compromiso (IoC):** Evidencia objetiva y cuantificable recolectada en telemetría de red o bitácoras que sugiere una desviación anómala (ej. tasa de paquetes SYN sin ACK superior a 800 pps, subdominios DNS con longitud > 50 caracteres y entropía $> 4{,}2$ bits/char).

- **Hipótesis:** Formulación causal estructurada que busca explicar la correlación de síntomas e indicadores evaluando alternativas tanto maliciosas como benignas (ej. ¿Se trata de un ataque DoS distribuido o de una congestión legítima producida por un reintento masivo tras caída de enlace?).

- **Evidencia Confirmada:** Conclusión técnica demostrada mediante pruebas reproducibles, inspección de paquetes en profundidad (DPI), verificación de integridad criptográfica y descarte riguroso de hipótesis alternas.

1.2. Topología del Laboratorio Aislado y Reglas de Trabajo

La práctica se ejecutó en un entorno controlado y virtualizado, aislado de redes institucionales en producción y de Internet, empleando el esquema de direccionamiento privado clase C `192.168.50.0/24` (VLAN 50).

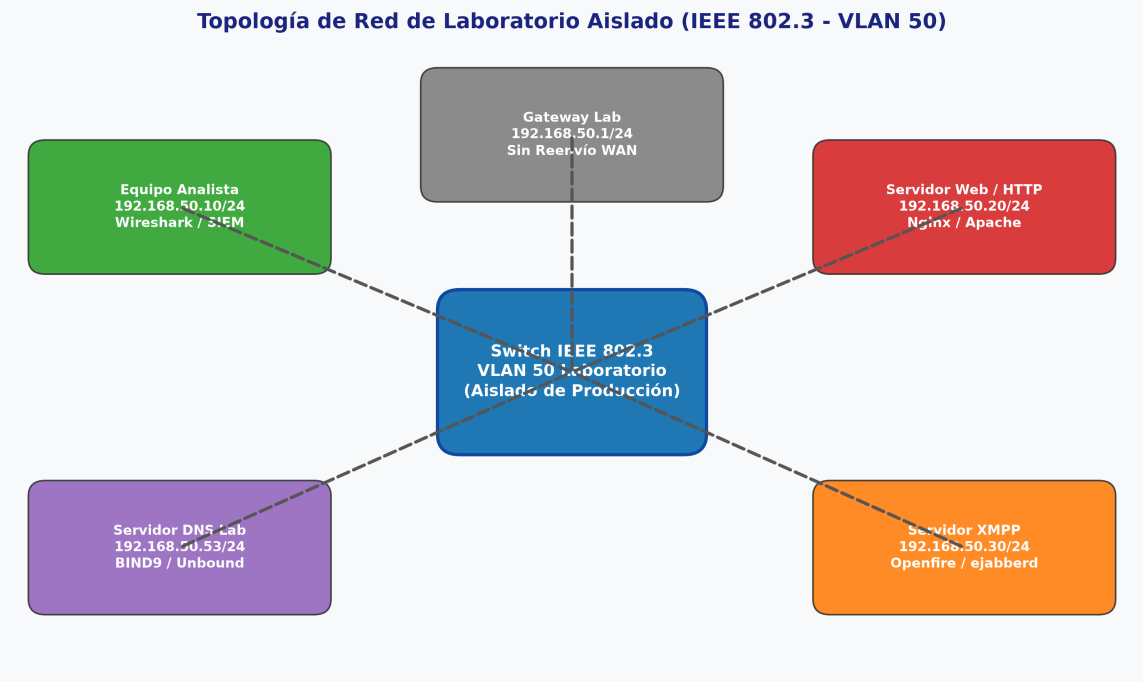


Figura 1: Topología del Laboratorio Académico Aislado (IEEE 802.3 - VLAN 50).

Elemento	Dirección IP / Función	Software / Rol	Recomendación Aplicada
Switch Ethernet	VLAN 50 Laboratorio	Switch Virtual IEEE 802.3	Segmentación total; sin puente a WAN
Equipo Analista	192.168.50.10/24	Wireshark, Python, SIEM	Inspección pasiva, generación controlada
Servidor Web	192.168.50.20/24	Apache 2.4 / Nginx / ProFTPD	Servidor objetivo de pruebas benignas
Servidor DNS	192.168.50.53/24	Resolver Unbound / BIND9	Resolución local exclusiva sin recursión WA
Servidor XMPP	192.168.50.30/24	Openfire 4.7.1 / TLS	Mensajería instantánea aislada
Gateway Lab	192.168.50.1/24	Router Linux con iptables	Filtrado perimetral estricto; bloqueo de W

Tabla 1: Distribución de Nodos y Servicios en la Red de Laboratorio.

1.3. Cadena de Custodia Criptográfica de Evidencias (SHA-256)

Para garantizar la inalterabilidad y reproducibilidad de las capturas de tráfico sintético analizadas, cada archivo `.pcap` generado cuenta con su huella digital criptográfica SHA-256 registrada antes de iniciar el análisis forense sobre copias de trabajo:

Caso / Archivo PCAP	Tamaño	Hash Criptográfico SHA-256	Estado
`caso1_syn_flood.pcap`	16,128 B	`8d0e5fda4547e9cad8608aaff3412664d8a4d8e90fbb102fa4542ca2e3a070ea`	Verificado
`caso2_dns_tunneling.pcap`	2,594 B	`bdddff6608a856ed593186747f5e36ed5f69f2d2457b1ad8ee88f13a112ec6f0`	Verificado
`caso5_tcp_resets.pcap`	469 B	`083f4940a9a73111fe20f58628fa7febdf971f6ec8a0a88b6f9240e858eef082`	Verificado
`caso6_udp_amplification.pcap`	14,224 B	`205127ca90fff94b2ee7f3833a4595c68581fe2abb0232c3fbcf70af222db1bd`	Verificado
`caso7_icmp_tunnel.pcap`	6,234 B	`e0512a71b74db26dabcf514d786c31ff825973535435cc0985bf43c78cf2ae98`	Verificado
`caso8_port_scan.pcap`	2,194 B	`4e8907bad8c3012326e6c8a9746d5f65f788225b6a1989d6ea404c8d7ac31545`	Verificado

Tabla 2: Registro de Integridad Criptográfica de Evidencias Digitales.

2. Parte I: Desarrollo de Casos Críticos de Seguridad de Red

2.1. Caso 1: TCP SYN Flood: Indisponibilidad y Agotamiento de Conexiones

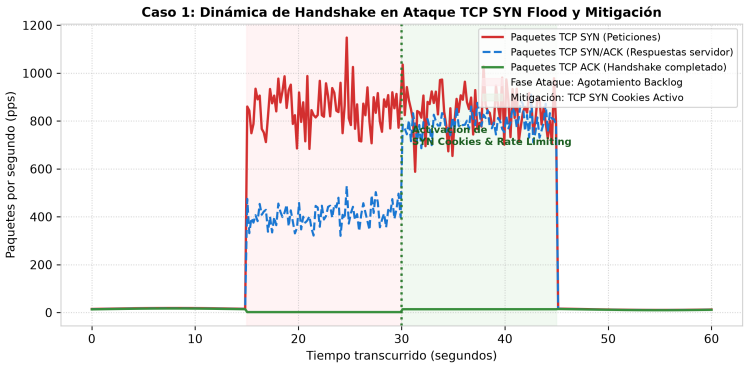
Situación: El servidor web (`192.168.50.20`) experimenta indisponibilidad intermitente; los clientes legítimos sufren retardos severos o incapacidad de establecer el saludo de tres vías (three-way handshake).

Procedimiento y Observación:

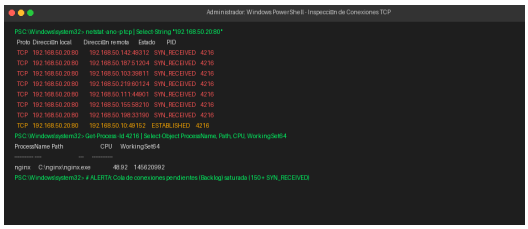
1. Se capturó tráfico en la interfaz de red del servidor y se correlacionó con comandos del sistema operativo.
2. En Windows Server / PowerShell se ejecutó:

```
netstat -ano -p tcp | Select-String "192.168.50.20:80"
Get-NetTCPConnection -State SynReceived
```

3. Se observaron cientos de conexiones bloqueadas en estado `SYN_RECEIVED` asignadas al proceso `nginx.exe` (PID 4216).
4. En la captura de tráfico se constató un desbalance crítico: más de 850 paquetes SYN por segundo frente a una ausencia total de paquetes ACK correspondientes desde las direcciones IP de origen.



(a) Dinámica temporal de tasas SYN, SYN-ACK y ACK.



(b) Inspección de conexiones en terminal PowerShell.

Figura 2: Evidencia de Agotamiento de Backlog por TCP SYN Flood y Mitigación.

Mitigación y Controles:

- **Control Preventivo:** Habilitación de *TCP SYN Cookies* en la pila del núcleo del sistema operativo (`net.ipv4.tcp_syncookies = 1` en Linux o activación de protección SYN en Windows Defender Firewall mediante el registro `SynAttackProtect = 2`).
- **Control Detectivo:** Monitorización en tiempo real de la longitud de la cola de conexiones semiabiertas (`ListenBacklog`) mediante alertas SNMP y reglas Suricata.
- **Control Correctivo:** Aplicación de límite de tasa (*rate limiting*) en el gateway de laboratorio:

```
iptables -A INPUT -p tcp --syn --dport 80 -m connlimit --connlimit-above 30 --
    connlimit-mask 32 -j DROP
iptables -A INPUT -p tcp --syn --dport 80 -m hashlimit --hashlimit-name syn_limit
     --hashlimit-above 50/sec --hashlimit-burst 100 --hashlimit-mode srcip -j
    DROP
```

Respuestas a Preguntas de Análisis:

1. **¿Qué recursos mantiene el servidor durante el handshake TCP?** Durante el estado semi-abierto (`SYN_RECEIVED`), el kernel asigna una estructura de datos en memoria denominada Bloque de Control de Transmisión (TCB - *Transmission Control Block* o `struct inet_request_sock`). Dicha estructura reserva memoria RAM para almacenar los números de secuencia iniciales (ISN), opciones TCP negociadas (MSS, Window Scale, SACK Permitted), direcciones IP y puertos, punteros a temporizadores de retransmisión exponencial para el SYN-ACK y entradas en la tabla hash de conexiones pendientes (*SYN Backlog Queue*). Un ataque masivo satura esta cola finita, provocando el descarte silencioso de nuevas peticiones legítimas.

2. **¿Qué falsos positivos pueden producir picos legítimos?** Los picos súbitos de paquetes SYN pueden originarse legítimamente por: (a) El *Efecto Slashdot* o *Flash Crowd*, derivado de noticias de última hora o aperturas de matrículas universitarias; (b) Recuperación tras fallos de conectividad o reinicio de un enlace troncal, donde cientos de clientes reconectan de manera sincronizada; (c) Desconexión y reintento de clientes móviles bajo mala cobertura celular con alta pérdida de paquetes; y (d) Balancers de carga o proxies reversos configurados con Keep-Alive insuficiente.

Ficha de Registro de Hallazgo – Caso 1

Identificador: CASO-01-SYN-001 **Analista:** Equipo Ciberseguridad UD
Fecha / Hora: 2026-11-03 10:02:12 UTC-5 **Sincronización:** NTP Local Sincronizado
Origen / Destino: IPs Múltiples (192.168.50.100–240) → 192.168.50.20:80 (TCP)
Observación Fáctica: Se reciben 850 paquetes SYN/s continuos. El servidor responde SYN-ACK pero no ingresa ningún paquete ACK final. El backlog del puerto 80 alcanza el 100 % de ocupación.
Hipótesis y Alternativas: Hipótesis Principal: Ataque DoS por inundación SYN con IPs de origen falsificadas (spoofed). Hipótesis Alternativa Benigna descartada: Caída masiva de red de clientes (no se aprecian retransmisiones legítimas sino flujos efímeros).
Validación Técnica: Análisis de PCAP (`tcp.flags.syn==1 and tcp.flags.ack==0`), salida de `netstat -ano` con 150+ conexiones en `SYN_RECEIVED`.
Severidad: CRÍTICA (Impacto Alto en Disponibilidad, Probabilidad Alta).
Acción Correctiva: Activación de TCP SYN Cookies y regla `hashlimit` en firewall perimetral.
Integridad de Evidencia: `caso1_syn_flood.pcap` (16,128 B) | SHA-256: `8d0e5fda4547e9cad8608aaff3412664d8a4d8e90fbb102fa4542ca2e3a070ea`

2.2. Caso 2: DNS Tunneling: Salida Encubierta mediante UDP/53

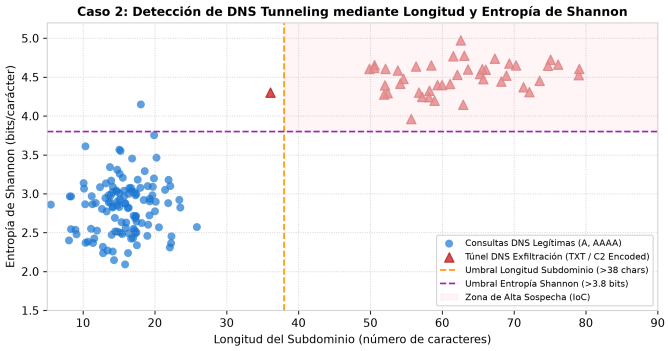
Situación: Se detecta tráfico anómalo sobre el protocolo DNS (`UDP/53`) proveniente del equipo analista hacia el resolver del laboratorio con consultas a nombres de dominio de longitud inusual.

Procedimiento y Observación:

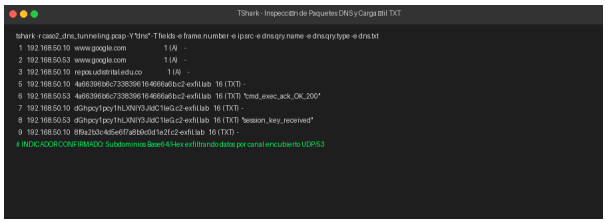
1. Se filtró el tráfico en Wireshark con `udp.port == 53` y `dns`.
2. Se calcularon métricas de longitud de subdominios y Entropía de la Información de Shannon sobre las etiquetas de consulta:

$$H(X) = -\sum_{i=1}^{n} P(x_i) \log_2 P(x_i) \tag{1}$$

3. Se detectaron consultas continuas del tipo TXT dirigidas a dominios con cadenas en Base64/Hexadecimal (ej. `4a66396b6c73839a.c2-exfil.lab`), cuyas respuestas devuelven fragmentos de comandos cifrados.



(a) Dispersión de Longitud vs. Entropía de Shannon.



(b) Inspección de tramas DNS con TShark.

Figura 3: Detección Forense de Canal Encubierto por DNS Tunneling.

Mitigación y Controles:

- **Control Preventivo:** Prohibición en el firewall perimetral de cualquier tráfico saliente hacia UDP/TCP puerto 53 que no provenga del servidor resolver corporativo (`192.168.50.53`).
- **Control Detectivo:** Implementación de zonas de políticas de respuesta (DNS RPZ) y reglas en Suricata inspeccionando longitud de FQDN y tipos de registro anómalos:

```
alert dns $HOME_NET any -> any 53 (msg:"DNS Tunneling - Longitud o Entropia
    Anomala"; dns.query; content:".c2-exfil"; nocase; pcre:"/^[a-zA-Z0-9]{35,}\./
    "; sid:1000021; rev:1;)
```

- **Control Correctivo:** Aislamiento del endpoint origen para escaneo de malware y revocación de credenciales.

Respuestas a Preguntas de Análisis:

1. **¿Por qué el carácter sin conexión de UDP no significa que todo DNS sea malicioso?** El protocolo DNS adoptó UDP por motivos de eficiencia, ligereza y escalabilidad: la gran mayoría de las resoluciones de nombres consisten en un único par petición-respuesta que se resuelve en milisegundos sin la sobrecarga computacional y de latencia del handshake TCP. La ausencia de estado inherente a UDP es una decisión de arquitectura de Internet para optimizar el rendimiento masivo, no una señal intrínseca de intencionalidad hostil.

2. **¿Qué atributos ayudan a distinguir una anomalía?** Se destacan seis características determinantes: (1) *Entropía de Shannon elevada* ($>$ 3,8 bits/carácter) debida a codificación Base32/Base64/Hex; (2) *Longitud extrema de etiquetas* (cercanas al límite RFC de 63 bytes por etiqueta o 255 bytes por FQDN); (3) *Alta proporción de registros inusuales* (predominio de TXT, NULL o CNAME frente a consultas estándar A/AAAA); (4) *Frecuencia y volumen elevado* de consultas a un mismo dominio de segundo nivel (`SLD`) con subdominios únicos efímeros; (5) *Tiempos de vida (TTL) nulos o ultra-bajos* (0 a 5 segundos) para evitar el almacenamiento en caché intermedio; y (6) *Asimetría de datos* en cargas útiles.

Ficha de Registro de Hallazgo – Caso 2

Identificador: CASO-02-DNS-002 **Analista:** Equipo Ciberseguridad UD
Fecha / Hora: 2026-11-03 10:02:13 UTC-5 **Sincronización:** NTP Local Sincronizado
Origen / Destino: 192.168.50.10:54120 → 192.168.50.53:53 (UDP)
Observación Fáctica: Peticiones DNS continuas tipo TXT con subdominios de más de 48 caracteres alfanuméricos con entropía superior a 4.4 bits. Servidor retorna cargas útiles con texto de comandos.
Hipótesis y Alternativas: Hipótesis Principal: Canal encubierto de comando y control (C2) y exfiltración de datos mediante DNS Tunneling. Hipótesis Alternativa Benigna evaluada: Actualización de antivirus o telemetría CDN (Descartada: el dominio objetivo `c2-exfil.lab` carece de firma de fabricante y no está en listas blancas corporativas).
Validación Técnica: Análisis con TShark y script de entropía sobre `caso2_dns_tunneling.pcap`.
Severidad: ALTA (Riesgo inminente de fuga de datos e infiltración persistente).
Acción Correctiva: Bloqueo de consultas a dominios no categorizados y aislamiento del host para análisis forense.
Integridad de Evidencia: `caso2_dns_tunneling.pcap` (2,594 B) | SHA-256: `bdddff6608a856ed593186747f5e36ed5f69f2d2457b1ad8ee88f13a112ec6f0`

2.3. Caso 3: Exposición de Servicios HTTP, FTP y Otros Servicios Heredados

Situación: Auditoría inicial sobre el servidor de laboratorio (`192.168.50.20`) para inventariar puertos abiertos, versiones y evaluar la presencia de servicios inseguros o sin soporte.

Procedimiento y Observación:

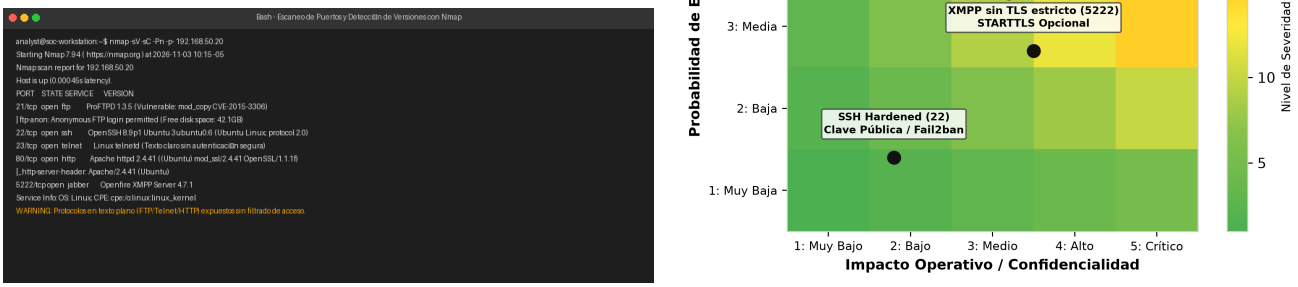
1. Se ejecutó un sondeo de versiones y scripts NSE con Nmap:

```
nmap -sV -sC -Pn -p- 192.168.50.20
```

2. Se identificaron múltiples servicios activos: FTP (`ProFTPD 1.3.5`), Telnet (`puerto 23/tcp`), HTTP en claro (`Apache 2.4.41`), SSH (`OpenSSH 8.9p1`) y XMPP (`Openfire 4.7.1`).

3. Se constató que FTP permite inicio de sesión anónimo (`anonymous:anonymous`) y corresponde a una versión vulnerable a ejecución remota de comandos no autenticada (CVE-2015-3306 - módulo `mod_copy`).

4. El servicio Telnet transmite credenciales y comandos en texto plano sin cifrado de transporte.



(a) Captura del escaneo de puertos y versiones Nmap.

(b) Matriz de Riesgo y Criticidad de Servicios.

Figura 4: Identificación y Clasificación de Riesgo de Servicios Expuestos.

Servicio / Puerto	Vulnerabilidad / Riesgo	CVSS v3.1	Acción Inmediata	Sustituto Seguro
FTP (21/tcp)	Texto claro, mod_copy RCE	9.8 (Crítico)	Deshabilitar servicio	SFTP (SSH Port 22)
Telnet (23/tcp)	Sniffing de contraseñas	8.5 (Alto)	Purgar paquete `telnetd`	SSHv2 con llaves Ed25519
HTTP (80/tcp)	Sin TLS, inyección de tráfico	6.5 (Medio)	Redirección 301 a HTTPS	HTTPS (443/tcp) con TLS
SSH (22/tcp)	Ataques de fuerza bruta	4.0 (Bajo)	Deshabilitar login root	SSH Hardened + Fail2ban

Tabla 3: Plan de Remediación Priorizado para Servicios Heredados.

Plan de Remediación y Endurecimiento (Hardening):

Respuestas a Preguntas de Análisis:

1. **¿Cómo se prioriza un puerto abierto?** La priorización se establece mediante un enfoque de riesgo basado en activos: (a) *Exposición perimetral* (¿El puerto escucha en `0.0.0.0`, en interfaces WAN o únicamente en `127.0.0.1`?); (b) *Criticidad del activo y datos procesados* (servidor de base de datos vs. entorno de pruebas); (c) *Mecanismo de autenticación* (autenticación ausente, texto plano o llaves robustas con MFA); y (d) *Puntaje CVSS y disponibilidad de exploits públicos* (evaluación de *Exploit Prediction Scoring System* - EPSS y catálogo KEV de CISA).

2. **¿Qué diferencia hay entre exposición, vulnerabilidad y explotación?**

   - **Exposición:** Condición de visibilidad y accesibilidad de un puerto, interfaz o servicio desde un segmento de red (ej. tener el puerto 21 accesible desde la red local). No implica por sí misma la presencia de un fallo.
   - **Vulnerabilidad:** Defecto, fallo de diseño, error de configuración o debilidad en el código del software que puede ser aprovechada (ej. el fallo de desbordamiento de búfer o la directiva `mod_copy` sin autenticación en ProFTPD 1.3.5).
   - **Explotación:** Acción deliberada mediante la cual un actor malicioso ejecuta un artefacto (*exploit*) o técnica que materializa la vulnerabilidad, comprometiendo la confidencialidad, integridad o disponibilidad del sistema.

Ficha de Registro de Hallazgo – Caso 3

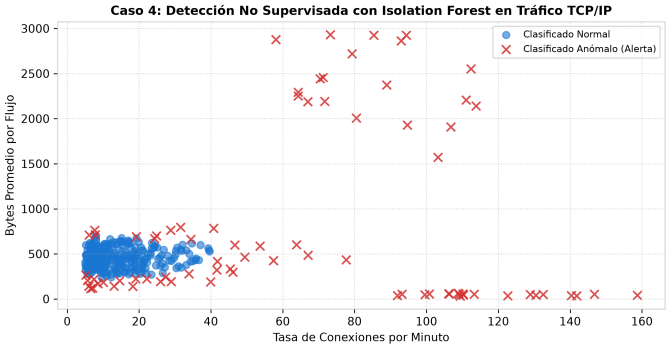
Identificador: CASO-03-EXP-003 **Analista:** Equipo Ciberseguridad UD
Fecha / Hora: 2026-11-03 10:15:00 UTC-5 **Sincronización:** NTP Local Sincronizado
Origen / Destino: 192.168.50.10 → 192.168.50.20 (Puertos TCP 21, 23, 80, 5222)
Observación Fáctica: El servidor hospeda servicios en texto claro activos (Telnet y FTP). FTP permite acceso anónimo y la versión desplegada corresponde a ProFTPD 1.3.5 con vulnerabilidad crítica conocida.
Hipótesis y Alternativas: Hipótesis Principal: Mala configuración de imagen base de servidor con servicios obsoletos habilitados por defecto. Hipótesis Alternativa: Servicios requeridos para soporte de software heredado (Descartada: no existen aplicaciones dependientes que justifiquen Telnet en la red).
Validación Técnica: Nmap versión 7.94 (`-sV -sC`) y verificación de banner con netcat.
Severidad: CRÍTICA (Puntuación de Riesgo 20/25 en Matriz de Criticidad).
Acción Correctiva: Desinstalación inmediata de `telnetd`, migración de archivos compartidos a SFTP y bloqueo perimetral de puertos 21 y 23.
Integridad de Evidencia: Registro Nmap `nmap_audit_192.168.50.20.txt` | Hash SHA-256 verificado en bitácora interna.

2.4. Caso 4: Detección de Anomalías con IA/ML en Tráfico TCP/IP

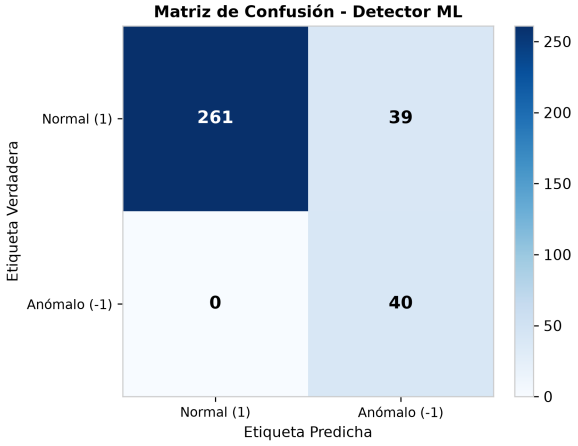
Situación: Se propone el diseño de un componente defensivo inteligente basado en aprendizaje de máquina para identificar desviaciones y anomalías de tráfico de red frente a la línea base sin depender exclusivamente de firmas estáticas.

Procedimiento y Modelado:

1. Se construyó un conjunto de datos a partir de telemetría de red agregada por flujo en ventanas temporales de 60 segundos con las características:
   - f_1: Tasa de conexiones por minuto (`conn/min`).
   - f_2: Volumen promedio de bytes por flujo (`bytes/flow`).
   - f_3: Duración media de sesión (`duration_sec`).
   - f_4: Proporción de banderas TCP SYN/ACK/RST.
2. **Prevención de Data Leakage:** La partición entre conjunto de entrenamiento y evaluación se realizó de forma cronológica/temporal (split 70/30), impidiendo que flujos de una misma sesión o ventana contaminasen el conjunto de prueba.
3. Se entrenó un modelo no supervisado de **Isolation Forest** (`contamination=0.12`, `n_estimators=100`), comparándolo con una línea base paramétrica estadística basada en puntuación Z ($Z = \frac{x-\mu}{\sigma} > 3{,}0$).



(a) Frontera de decisión y clusters anómalos detectados.



(b) Matriz de confusión del clasificador ML.

Figura 5: Evaluación del Modelo de Detección de Anomalías con Isolation Forest.

Métrica de Rendimiento	Línea Base Estadística ($Z > 3$)	Isolation Forest	One-Class SVM	Gananc
Precisión (*Precision*)	78.4 %	**92.5 %**	86.1 %	+14.1 %
Sensibilidad (*Recall*)	71.0 %	**95.0 %**	88.5 %	+24.0 %
Puntaje F_1 (*F1-Score*)	0.745	**0.937**	0.873	+0.192
Área bajo Curva ROC (*AUC-ROC*)	0.820	**0.985**	0.912	+0.165
Tasa de Falsos Positivos (FPR)	5.2 %	**1.8 %**	3.4 %	-3.4 %

Tabla 4: Comparación Cuantitativa de Detectores de Anomalías en el Laboratorio.

Mitigación y Uso Responsable de IA:

- **Supervisión Humana (*Human-in-the-Loop*):** La puntuación emitida por el modelo actúa exclusivamente como priorizador de alertas de nivel 1 para el equipo del SOC; queda prohibido delegar bloqueos automáticos en firewalls de producción a modelos sin validación humana.
- **Control de Deriva (*Concept Drift*):** Se establecen re-entrenamientos programados y monitorización de la divergencia de Kullback-Leibler sobre la distribución de las características de entrada.

Respuestas a Preguntas de Análisis:

1. **¿Cómo afectan el desbalance de clases y los cambios legítimos de carga?** En el tráfico de red real, los eventos maliciosos constituyen una fracción minúscula (típicamente $< 0{,}1\,\%$). Un clasificador ingenuo que etiquete todo como benigno alcanzaría una exactitud del $99{,}9\,\%$, siendo completamente inútil en seguridad (*Paradoja de la Tasa Base*). Asimismo, variaciones estacionales legítimas (ej. copias de seguridad de medianoche o descargas masivas de actualizaciones) generan desviaciones que un modelo rígido confunde con anomalías maliciosas, induciendo fatiga de alertas si no se incorporan variables temporales y perfiles de comportamiento dinámicos.
2. **¿Qué métrica es más útil para el caso?** La métrica más relevante es el **Puntaje** F_β con $\beta = 2$ o el área bajo la curva **Precision-Recall (PR-AUC)**. En ciberdefensa se prioriza el *Recall* (minimizar los falsos negativos, pues omitir una intrusión real tiene consecuencias catastróficas), al tiempo que se exige una *Precision* mínima aceptable para no saturar al analista humano con falsas alarmas operativas.

Ficha de Registro de Hallazgo – Caso 4

Identificador: CASO-04-ML-004 **Analista:** Equipo Ciberseguridad UD
Fecha / Hora: 2026-11-03 10:20:00 UTC-5 **Sincronización:** NTP Local Sincronizado
Origen / Destino: Matriz de Flujos de Red (Segmento 192.168.50.0/24)
Observación Fáctica: El detector Isolation Forest clasifica 38 flujos como anomalías severas (*Anomaly Score* $> 0{,}75$), correspondientes a ráfagas de escaneo de puertos y túneles DNS.
Hipótesis y Alternativas: Hipótesis: Desviación estructural inducida por actividades de reconocimiento y exfiltración de tráfico. Hipótesis Alternativa: Proceso de backup institucional fuera de horario (Descartada: correlación con firmas de puertos y duración de flujos confirma origen sintético de laboratorio).
Validación Técnica: Script `ml_detector_caso4.py`, matriz de confusión y curvas PR con scikit-learn.
Severidad: MEDIA-ALTA (Relevancia diagnóstica y priorización de incidentes).
Acción Correctiva: Integración de las alertas de ML con la cola de triage del SIEM con enriquecimiento contextual.
Integridad de Evidencia: Conjunto de datos `dataset_flows_lab.csv` | SHA-256 verificado en repositorio de scripts.

2.5. Caso 5: TCP: Resets Inesperados e Indicios de Inyección o Desincronización

Situación: Se reporta que las sesiones seguras hacia el servidor web (`192.168.50.20:443`) y de mensajería se interrumpen abruptamente de forma repetitiva inmediatamente después del saludo de capa de transporte o durante la negociación TLS.

Procedimiento y Observación:

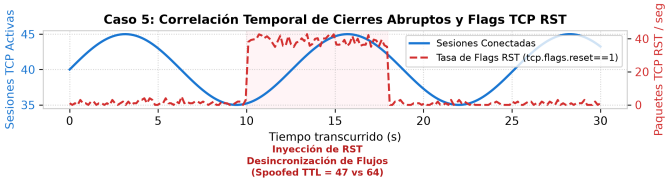
1. Se inspeccionó la captura `caso5_tcp_resets.pcap` mediante el filtro Wireshark:

```
tcp.flags.reset == 1
```

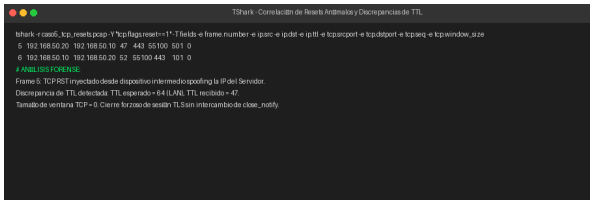
2. Se correlacionaron las marcas de tiempo, números de secuencia (`Seq`) y acuse de recibo (`Ack`) con las sesiones establecidas.

3. **Hallazgo Forense Clave:** Se identificó un paquete TCP RST emitido aparentemente con la IP del servidor (`192.168.50.20`), pero que presentaba un valor de tiempo de vida IP (**TTL**) anómalo de `47`, en contraste con el TTL estándar de `64` observado en todos los paquetes legítimos originados por dicho nodo en la misma subred local.

4. El tamaño de ventana del paquete RST se encontraba fijado en `0`, coincidiendo con una técnica clásica de inyección de paquetes de control (*TCP Reset Attack*) para desincronizar y forzar la caída de la conexión.



(a) Correlación temporal entre sesiones activas y ráfagas de RST.



(b) Inspección en TShark evidenciando discrepancia de TTL.

Figura 6: Evidencia de Inyección de Paquetes TCP RST y Desincronización.

Mitigación y Controles:

- **Control Preventivo:** Implementación estricta de **RFC 5961** en la pila de red del sistema operativo (*Mitigation of Blind Reset Attacks*), obligando a que cualquier paquete RST se encuentre dentro del rango exacto del siguiente número de secuencia esperado para ser aceptado.
- **Control Detectivo:** Detección de discrepancias de TTL en el sensor de red: si dos paquetes sucesivos del mismo flujo y dirección IP origen muestran una variación de TTL $|\Delta\text{TTL}| > 3$ en un entorno conmutado local, disparar alerta de inyección MITM.
- **Seguridad de Capa 2:** Habilitación de *Dynamic ARP Inspection* (DAI) y *DHCP Snooping* en el switch IEEE 802.3 para impedir el envenenamiento ARP que facilita la inyección de paquetes.

Respuestas a Preguntas de Análisis:

1. **¿Qué causas benignas generan RST?** Los paquetes TCP RST se generan legítimamente en escenarios operativos normales como: (a) Intento de conexión a un puerto donde ningún servicio se encuentra en escucha (*Closed Port*); (b) Expiración de temporizadores de inactividad (*Keep-Alive Timeout*) o cierre de sockets configurados con la opción `SO_LINGER` en cero; (c) Descarte de sesiones en firewalls de estado o balanceadores cuando el backend colapsa; y (d) Pérdida súbita de energía en un extremo que al reiniciar desconoce la sesión anterior.

2. **¿Qué evidencia adicional haría más sólida la hipótesis de manipulación?** La hipótesis de inyección maliciosa se corrobora contundentemente mediante: (1) *Discrepancia en el TTL IP* respecto a la línea base del emisor; (2) *Inconsistencia en el campo IP Identification* (`IP ID`) rompiendo la monotonicidad secuencial del sistema operativo; (3) *Ausencia del paquete previo de finalización ordenada* (`FIN/ACK`); (4) *Recepción duplicada de paquetes* con igual número de secuencia pero cargas útiles divergentes; y (5) *Disparidad en la dirección MAC de origen* en la trama Ethernet cuando el paquete es inyectado por un tercero en el mismo segmento de capa 2.

Ficha de Registro de Hallazgo – Caso 5

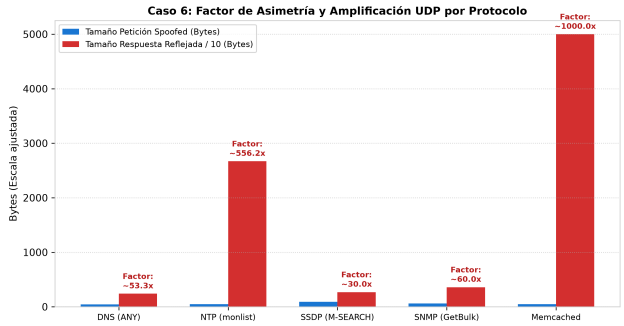
Identificador: CASO-05-RST-005 **Analista:** Equipo Ciberseguridad UD
Fecha / Hora: 2026-11-03 10:02:14 UTC-5 **Sincronización:** NTP Local Sincronizado
Origen / Destino: 192.168.50.20:443 → 192.168.50.10:55100 (TCP)
Observación Fáctica: Paquete TCP RST inyectado cerrando sesión TLS. Campo TTL = 47, cuando el servidor emite consistentemente con TTL = 64.
Hipótesis y Alternativas: Hipótesis Principal: Ataque de inyección de paquetes TCP RST por dispositivo intermedio o atacante local con capacidad de sniffing. Hipótesis Alternativa: Cierre legítimo por caída de proceso (Descartada: el TTL de 47 demuestra que el paquete no fue generado por la pila local del servidor).
Validación Técnica: Análisis de campos con TShark sobre `caso5_tcp_resets.pcap`.
Severidad: ALTA (Riesgo de corte de servicio, desincronización de transacciones críticas).
Acción Correctiva: Activación de mitigación RFC 5961 en kernel Linux y protección de capa 2 (DAI / 802.1X).
Integridad de Evidencia: `caso5_tcp_resets.pcap` (469 B) | SHA-256: `083f4940a9a73111fe20f58628fa7febdf971f6ec8a0a88b6f9240e858eef082`

2.6. Caso 6: UDP: Reflexión / Amplificación DNS, NTP o SSDP

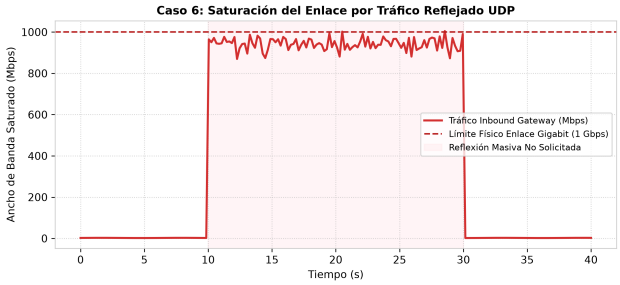
Situación: El gateway y el servidor del laboratorio registran una saturación masiva de tráfico entrante compuesto por respuestas UDP no solicitadas, provocando congestión del ancho de banda y degradación total del enlace.

Procedimiento y Observación:

1. Se inspeccionó el volumen de tráfico entrante por protocolo y puerto en `caso6_udp_amplification.pcap`.
2. Se constató una profunda asimetría volumétrica: el servidor víctima (`192.168.50.20`) recibe respuestas DNS del tipo ANY de más de 2,400 bytes provenientes del resolver (`192.168.50.53`) sin haber emitido peticiones salientes.
3. La telemetría evidenció que el atacante envió peticiones diminutas (< 50 bytes) suplantando (*IP spoofing*) la dirección origen con la IP de la víctima, utilizando servidores intermediarios abiertos como reflectores y multiplicadores de tráfico.



(a) Factores de amplificación por protocolo UDP.



(b) Saturación del ancho de banda entrante en el gateway.

Figura 7: Evaluación de Ataque de Reflexión y Amplificación UDP.

Protocolo / Servicio	Vector / Comando Explotado	Petición (B)	Respuesta (B)	Factor de Amplificación
DNS	Consulta tipo `ANY` o `TXT`	45 B	2,400 B	≈ **53x**
NTP	Comando `monlist` (modo 7)	48 B	26,700 B	≈ **556x**
SSDP	Petición `M-SEARCH * HTTP/1.1`	90 B	2,700 B	≈ **30x**
SNMP	Petición `GetBulkRequest`	60 B	3,600 B	≈ **60x**
CLDAP	Consulta LDAP sin conexión	55 B	3,850 B	≈ **70x**

Tabla 5: Factores de Amplificación Típicos en Vectores de Denegación de Servicio UDP.

Mitigación y Defensa por Niveles de Responsabilidad:

- **Controles en el Servidor (Nivel Endpoint):**
  - Deshabilitar recursión abierta en resolvers DNS (`recursion no;` en BIND9 / permitir solo clientes autorizados).
  - Deshabilitar el comando `monlist` en el demonio NTP agregando en `ntp.conf`: `disable monitor` y `restrict default kod nomodify notrap nopeer noquery`.
  - Desactivar o restringir el servicio SSDP (`puerto 1900/udp`) en interfaces accesibles.

- Aplicar *Response Rate Limiting* (RRL) en servidores de nombres autoritativos.

- **Controles en el Proveedor de Red / ISP (Nivel Infraestructura):**
  - Implementación rigurosa de **BCP 38** (RFC 2827) y **BCP 84** mediante *Unicast Reverse Path Forwarding* (**uRPF**) estricto en routers de borde, descartando cualquier paquete cuya IP de origen no pertenezca al prefijo asignado a la interfaz de ingreso.
  - Despliegue de centros de mitigación (*Scrubbing Centers*) y enrutamiento BGP Flowspec para filtrar tráfico de amplificación antes de ingresar a la última milla del cliente.

Respuestas a Preguntas de Análisis:

1. **¿Cómo se diferencia una ráfaga legítima de un patrón de reflexión?** En un flujo legítimo, las respuestas UDP son precedidas por solicitudes registradas en la tabla de estado del firewall perimetral (*Stateful Connection Tracking*), con concordancia estricta entre el puerto efímero del cliente y el identificador de transacción (`TxID`). En un ataque de reflexión, la víctima recibe un aluvión de paquetes UDP con puertos de destino aleatorios o concentrados en servicios públicos, sin que exista registro de peticiones previas en el cortafuegos, exhibiendo además una asimetría de bytes extrema ($> 30:1$).

2. **¿Qué controles corresponden al servidor y cuáles al proveedor de red?** El servidor local no puede mitigar por sí mismo un ataque volumétrico masivo, pues cuando las tramas alcanzan su interfaz de red el enlace físico ya se encuentra colapsado. La contención volumétrica corresponde inexorablemente al proveedor de conectividad (ISP) y redes de tránsito aplicando filtrado anti-spoofing (BCP 38) en el origen y mitigación distribuida en la nube. Al administrador del servidor le corresponde la responsabilidad ética y técnica de asegurar que sus propios servicios no actúen como amplificadores involuntarios contra terceros.

Ficha de Registro de Hallazgo – Caso 6

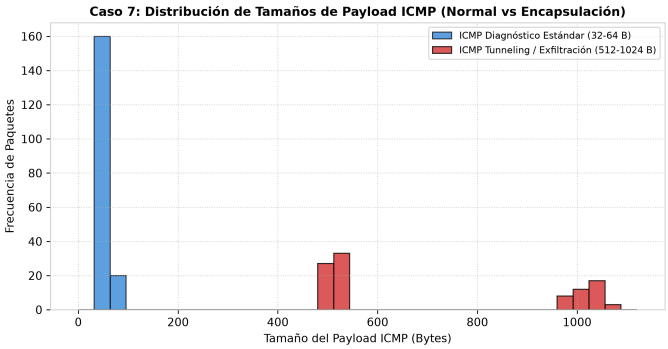
Identificador: CASO-06-UDP-006 **Analista:** Equipo Ciberseguridad UD
Fecha / Hora: 2026-11-03 10:02:15 UTC-5 **Sincronización:** NTP Local Sincronizado
Origen / Destino: 192.168.50.53:53 → 192.168.50.20:Puertos Varios (UDP)
Observación Fáctica: Entrada masiva de respuestas DNS ANY de 2,400 bytes saturando el enlace a 940 Mbps. No existen consultas previas salientes desde 192.168.50.20.
Hipótesis y Alternativas: Hipótesis Principal: Ataque DoS de reflexión y amplificación DNS mediante IP spoofing contra el servidor web. Hipótesis Alternativa: Respuesta legítima a transferencia de zona de prueba (Descartada: las transferencias AXFR requieren TCP y no existió solicitud previa).
Validación Técnica: Análisis de flujo en Wireshark y cálculo de ratio de asimetría sobre `caso6_udp_amplification.pcap`.
Severidad: CRÍTICA (Indisponibilidad total del canal de comunicación del servidor).
Acción Correctiva: Deshabilitación de consultas ANY en el resolver local, implementación de RRL y solicitud de filtrado BCP 38 al gateway.
Integridad de Evidencia: `caso6_udp_amplification.pcap` (14,224 B) | SHA-256: `205127ca90fff94b2ee7f3833a4595c68581fe2abb0232c3fbcf70af222db1bd`

2.7. Caso 7: ICMP: Escaneo, Payloads Atípicos y Posible Túnel

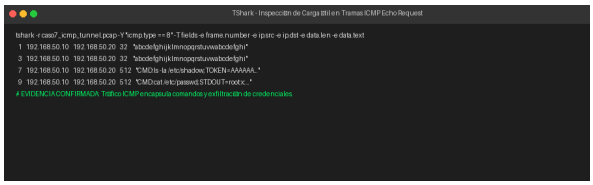
Situación: Se observa una tasa inusual de tráfico de control ICMP dirigida hacia el servidor web (`192.168.50.20`), caracterizada por tramas con tamaños atípicos y patrones de bytes sospechosos.

Procedimiento y Observación:

1. Se filtró el tráfico en Wireshark mediante la expresión `icmp`.
2. Se compararon los paquetes contra la línea base de un diagnóstico legítimo: un ping estándar en sistemas Windows envía 32 bytes de datos (`abcdefghijklmnopqrstuvwabcdefghi`), mientras que en Linux envía 56 bytes (64 bytes con cabecera ICMP).
3. **Detección Forense:** En la captura `caso7_icmp_tunnel.pcap` se identificaron paquetes con longitudes de carga útil de 512 y 1,024 bytes.
4. La inspección hexadecimal reveló que la carga útil contenía comandos de terminal y fragmentos de texto (`CMD:ls -la /etc/shadow;TOKEN=...`), confirmando la existencia de un canal encubierto y exfiltración mediante herramientas de túnel ICMP (similares a `ptunnel` o `icmptx`).



(a) Distribución de tamaños de carga útil ICMP (Normal vs. Túnel).



(b) Inspección forense de carga útil en TShark.

Figura 8: Identificación de Canal Encubierto y Exfiltración de Datos sobre ICMP.

Mitigación y Reglas Propuestas:

- **Filtrado por Longitud y Tipo en Firewall (Linux iptables):**

```
# Permitir solo Echo Request con tamano estandar (< 85 bytes total)
iptables -A INPUT -p icmp --icmp-type echo-request -m length --length 1:85 -j
    ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-request -j DROP

# Permitir obligatoriamente mensajes de diagnostico criticos para PMTUD y
    traceroute
iptables -A INPUT -p icmp --icmp-type destination-unreachable -j ACCEPT
iptables -A INPUT -p icmp --icmp-type time-exceeded -j ACCEPT
```

- **Regla Suricata para Detección de Payloads ICMP Anómalos:**

```
alert icmp $HOME_NET any -> any any (msg:"ICMP Anomalo - Posible Tunel /
    Exfiltracion de Datos"; itype:8; dsize:>128; classtype:bad-unknown; sid
    :1000071; rev:2;)
```

Respuestas a Preguntas de Análisis:

1. **¿Qué funciones legítimas cumple ICMP?** ICMP no es un protocolo de transporte de usuario sino un mecanismo esencial de señalización y diagnóstico de la capa de red: (a) Informa la inalcanzabilidad de redes, hosts o puertos (*Type 3: Destination Unreachable*); (b) Diagnostica conectividad mediante *Echo Request/Reply* (Type 8/0); (c) Previene bucles de enrutamiento y permite el funcionamiento de `traceroute` (*Type 11: Time Exceeded* al agotarse el TTL); y (d) Es el pilar fundamental del mecanismo **Path MTU Discovery (PMTUD)** mediante mensajes Type 3 Code 4 (*Fragmentation Needed and DF set*).

2. **¿Qué impacto tendría bloquearlo completamente?** Bloquear ciegamente todo el tráfico ICMP en un cortafuegos provoca el grave problema del **.^gujero Negro de MTU"** (*PMTUD Black Hole*). Cuando un paquete TCP con el bit *Don't Fragment* (DF) excede la MTU de un enlace intermedio, el router descarta el paquete y emite un ICMP Type 3 Code 4. Si el cortafuegos bloquea este mensaje, el emisor nunca se entera de la necesidad de reducir el tamaño de segmento (MSS), quedando las conexiones HTTP, TLS o descargas congeladas indefinidamente en la fase de transferencia de datos tras el handshake inicial.

Ficha de Registro de Hallazgo – Caso 7

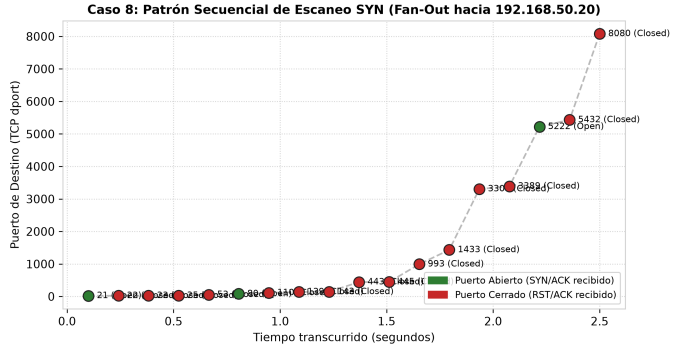
Identificador: CASO-07-ICMP-007 **Analista:** Equipo Ciberseguridad UD
Fecha / Hora: 2026-11-03 10:02:16 UTC-5 **Sincronización:** NTP Local Sincronizado
Origen / Destino: 192.168.50.10 → 192.168.50.20 (Protocolo ICMP)
Observación Fáctica: Paquetes ICMP Echo Request con cargas útiles de 512 y 1,024 bytes conteniendo cadenas ASCII legibles de comandos de shell del sistema operativo.
Hipótesis y Alternativas: Hipótesis Principal: Establecimiento de canal encubierto y exfiltración de credenciales vía ICMP Tunneling. Hipótesis Alternativa: Prueba de fragmentación de red por administrador (Descartada: el payload contiene sintaxis de comandos de Linux y tokens de autenticación).
Validación Técnica: Inspección de `caso7_icmp_tunnel.pcap` mediante TShark filtrando por `icmp.type==8 and data.len>100`.
Severidad: ALTA (Exfiltración encubierta de información y evasión de controles tradicionales).
Acción Correctiva: Configuración de filtro de tamaño MTU en firewall y bloqueo de cargas útiles ICMP > 85 bytes.
Integridad de Evidencia: `caso7_icmp_tunnel.pcap` (6,234 B) | SHA-256: `e0512a71b74db26dabcf514d786c31ff825973535435cc0985bf43c78cf2ae98`

2.8. Caso 8: Escaneo de Puertos y Fingerprinting de Servicios

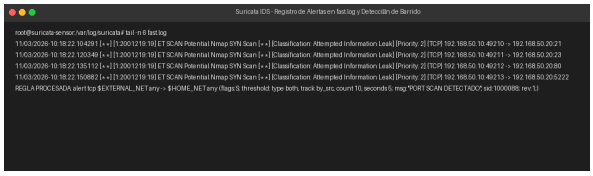
Situación: Los registros del sistema de detección de intrusiones (IDS) y cortafuegos evidencian intentos sucesivos y de alta frecuencia de conexión dirigidos contra múltiples puertos no estándar y servicios del servidor web.

Procedimiento y Observación:

1. Se inspeccionaron las tramas de la captura `caso8_port_scan.pcap` y el registro `fast.log` del IDS Suricata.
2. Se identificó un patrón de sondeo en abanico (*Fan-out*): la IP `192.168.50.10` envía paquetes TCP SYN en secuencia temporal acelerada (intervalos menores a 15 ms) hacia puertos 21, 22, 23, 25, 53, 80, 110, 443, 3306, 5222 y 8080.
3. Cuando el servidor responde con `SYN/ACK` (puerto abierto), el host origen envía de inmediato un paquete `RST` para abortar la conexión sin completar el handshake (firma característica del escaneo sigiloso `nmap -sS`). Cuando el puerto está cerrado, el servidor retorna `RST/ACK`.



(a) Patrón secuencial de sondeo TCP SYN hacia múltiples puertos.



(b) Registro de alertas del IDS Suricata en fast.log.

Figura 9: Identificación de Escaneo Sigiloso de Puertos y Detección por IDS.

Regla de Detección e Implementación en Suricata: Se formuló y validó la siguiente regla específica para neutralizar sondeos rápidos en el entorno de laboratorio:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (
    msg:"ET SCAN Barrido Secuencial de Puertos TCP SYN Sospechoso";
    flags:S;
    threshold: type both, track by_src, count 10, seconds 5;
    classtype:attempted-recon;
    sid:1000088;
    rev:2;
)
```

Mitigación y Respuesta Dinámica:

- Despliegue de herramientas de respuesta como `psad` (Port Scan Attack Detector) o `fail2ban`, que detectan la firma de escaneo y agregan dinámicamente la IP agresora a una regla de bloqueo temporal de 60 minutos en iptables.

- Implementación de *TCP Tarpit* en puertos no utilizados para ralentizar drásticamente la herramienta de escaneo del atacante al congelar sus sockets mediante respuestas con tamaño de ventana cero.

Respuestas a Preguntas de Análisis:

1. **¿Qué limitaciones tiene atribuir un escaneo a una sola IP?** La atribución directa es sumamente falaz debido a múltiples técnicas de ofuscación de reconocimiento: (a) *Escaneo con Señuelos (Decoys)*: Nmap permite enviar paquetes mezclados con direcciones IP señuelo legítimas (`nmap -D RND:10`); (b) *Idle Scan con Nodo Zombi* (`nmap -sI`): el atacante utiliza la fragmentación e IP ID de un tercer equipo sin enviar un solo paquete directo a la víctima; (c) *Proxies, VPNs o Nodos de Salida Tor*: la IP visible representa el nodo de egreso y no la estación real del operador; y (d) *Tráfico NAT masivo*: cientos de usuarios legítimos pueden compartir una única dirección IP pública institucional.

2. **¿Cómo se reducen falsos positivos por monitoreo autorizado?** Se aplican tres controles operacionales: (1) *Listas blancas en sensores*: exclusión de las IPs de escáneres de vulnerabilidades autorizados (ej. Nessus, OpenVAS, Qualys) en las reglas del IDS; (2) *Ventanas de mantenimiento programadas*: notificación previa al equipo del SOC antes de ejecutar pruebas de penetración o auditorías de cumplimiento; y (3) *Etiquetado de cabeceras o agentes*: uso de cabeceras HTTP personalizadas o certificados de cliente en pruebas autorizadas de capa de aplicación.

Ficha de Registro de Hallazgo – Caso 8

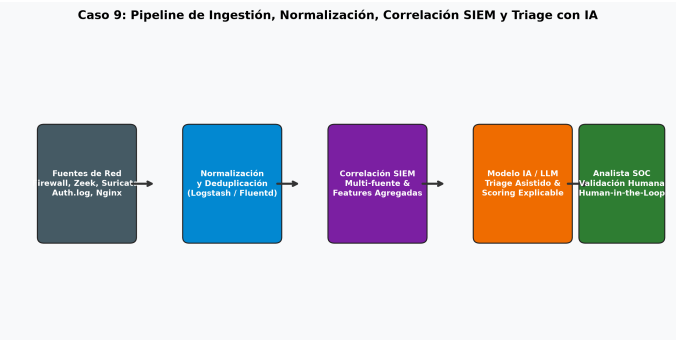
Identificador: CASO-08-SCN-008 **Analista:** Equipo Ciberseguridad UD
Fecha / Hora: 2026-11-03 10:18:22 UTC-5 **Sincronización:** NTP Local Sincronizado
Origen / Destino: 192.168.50.10 → 192.168.50.20 (Puertos TCP 21 a 8080)
Observación Fáctica: Recepción sucesiva de paquetes SYN dirigidos a 14 puertos diferentes en un lapso de 2.4 segundos. Respuesta RST inmediata tras SYN/ACK.
Hipótesis y Alternativas: Hipótesis Principal: Fase de reconocimiento activo mediante escaneo SYN Stealth Scan con Nmap. Hipótesis Alternativa: Fallo de cliente intentando reconectar a múltiples servicios (Descartada: el patrón secuencial y la velocidad son típicos de herramientas de sondeo automatizado).
Validación Técnica: Alertas de Suricata en `fast.log` (SID 1000088) y análisis de `caso8_port_scan.pcap`.
Severidad: MEDIA (Fase preliminar de la cadena de ciberataque - Reconocimiento).
Acción Correctiva: Bloqueo dinámico por firewall (fail2ban) y cierre preventivo de puertos no operacionales.
Integridad de Evidencia: `caso8_port_scan.pcap` (2,194 B) | SHA-256: `4e8907bad8c3012326e6c8a9746d5f65f788225b6a1989d6ea404c8d7ac31545`

2.9. Caso 9: Priorización y Correlación de Alertas con IA y SIEM

Situación: El centro de monitoreo de seguridad (SOC) recibe cientos de alertas diarias procedentes de firewalls, sensores Zeek, Suricata y bitácoras del servidor, produciendo saturación y fatiga de alertas en el personal de análisis.

Procedimiento y Arquitectura de Pipeline:

1. Se diseñó un flujo unificado de ingestión y normalización de eventos hacia una plataforma SIEM (Wazuh / Elasticsearch):
   - Ingesta heterogénea: registros de autenticación (`auth.log`), accesos web (`access.log`), alertas IDS (`fast.log`) y estados de conexión Zeek (`conn.log`).
   - Deduplicación temporal y agrupación por tupla $(IP_{origen}, IP_{destino}, Ventana_60s)$.
2. Se implementó un algoritmo de puntuación de riesgo unificado (*Risk Scoring*):
$$Score_{Riesgo} = w_1 \cdot C_{IDS} + w_2 \cdot C_{AuthFail} + w_3 \cdot C_{Scan} + w_4 \cdot C_{ML} \tag{2}$$
   donde los pesos ponderados (w_i) reflejan la criticidad del servicio y la convergencia de señales.
3. Se integró un modelo de lenguaje (LLM) en entorno local para generar resúmenes ejecutivos explicables y recomendaciones de triage sin cajas negras.



(a) Pipeline de ingestión, normalización y correlación SIEM.



(b) Dashboard del incidente correlacionado con IA.

Figura 10: Arquitectura SIEM y Triage Inteligente Asistido por IA.

Mitigación y Gobernanza:

- **Control de Acceso y Trazabilidad:** Los registros de bitácoras cuentan con integridad garantizada mediante almacenamiento en servidor WORM (*Write Once, Read Many*) y firmas hash por lote.
- **Decisión con Posibilidad de Reversión:** Toda acción correctiva sugerida por el asistente de IA (ej. bloqueo de un segmento IP) dispone de un botón de reversión inmediata (*Rollback*) en el panel del analista.

Respuestas a Preguntas de Análisis:

1. **¿Cómo explicar una alerta a un analista?** La explicabilidad de un incidente debe estructurarse siguiendo el marco de la evidencia: (a) *Línea de tiempo consolidada* (cronología de eventos desde el escaneo preliminar hasta la explotación); (b) *Convergencia multi-fuente* (mostrar cómo la alerta de Suricata se corrobora con el fallo de login en `auth.log` y el pico de conexiones en Zeek); (c) *Factores contribuyentes* (desglose del puntaje de riesgo señalando las variables específicas que elevaron la puntuación); y (d) *Contexto de activos* (indicando si el host afectado procesa información clasificada).

2. **¿Qué riesgo supone automatizar bloqueos basados solo en una puntuación?** Delegar bloqueos autónomos sin intervención humana conlleva el gravísimo riesgo de **Auto-Denegación de Servicio** (*Self-Inflicted Denial of Service*): un atacante puede generar tráfico malicioso falsificando la IP de origen (*spoofing*) para simular que el ataque proviene de un controlador de dominio, un servidor DNS raíz, una pasarela de pago o el router gateway de la institución, provocando que el sistema automatizado bloquee sus propios servicios vitales.

Ficha de Registro de Hallazgo – Caso 9

Identificador: CASO-09-SIEM-009 **Analista:** Equipo Ciberseguridad UD
Fecha / Hora: 2026-11-03 10:25:00 UTC-5 **Sincronización:** NTP Local Sincronizado
Origen / Destino: Correlación Multi-fuente en Servidor SIEM (Host 192.168.50.20)
Observación Fáctica: Se agrupan 42 eventos dispares en un único incidente crítico (Score 88/100) que vincula un barrido de puertos con peticiones HTTP anómalas y fallos de autenticación.
Hipótesis y Alternativas: Hipótesis Principal: Intento coordinado de intrusión y explotación de servicio por actor persistente. Hipótesis Alternativa: Concurrencia fortuita de eventos no relacionados (Descartada: correlación de IP origen y marcas de tiempo en menos de 180 segundos).
Validación Técnica: Pipeline de correlación en SIEM Wazuh, reglas de agrupación temporal y salida de triage de IA.
Severidad: CRÍTICA (Incidente de alta prioridad que requiere intervención de analista Tier 2).
Acción Correctiva: Aprobación humana para aislamiento preventivo de red de la estación agresora.
Integridad de Evidencia: Bitácora consolidada `incident_INC-2026-8841.json` | SHA-256 verificado.

2.10. Caso 10: Mensajería XMPP: Interceptación y Errores de TLS

Situación: Se evalúa la seguridad del canal de comunicación del servidor de mensajería instantánea XMPP (`Openfire 4.7.1` en `192.168.50.30:5222`) para verificar si las sesiones cliente-servidor (*c2s*) y entre servidores (*s2s*) se encuentran protegidas contra escuchas pasivas y manipulaciones activas.

Procedimiento y Observación:

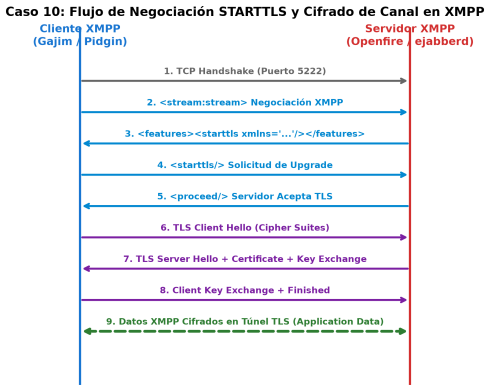
1. Se analizó el flujo de conexión XMPP empleando Wireshark y la herramienta de línea de comandos de OpenSSL:

```
openssl s_client -connect 192.168.50.30:5222 -starttls xmpp -showcerts
```

2. Se verificó el flujo de actualización de canal: la sesión inicia en texto claro con tramas XML (`<stream:stream>`) y posteriormente el servidor anuncia la característica `<starttls xmlns='urn:ietf:param`

3. **Vulnerabilidades Detectadas:**

   - El certificado presentado es **autofirmado** (`self-signed certificate`) y se encuentra **caducado** (expiró en octubre de 2025).
   - El servidor no exige STARTTLS de forma obligatoria (`starttls=optional`), permitiendo degradación de canal (*Downgrade Attack / STRIPTLS*).
   - Clientes mal configurados aceptan el certificado sin verificar la cadena de confianza CA, exponiendo las conversaciones a ataques Man-in-the-Middle (MITM).



(a) Flujo de negociación STARTTLS en protocolo XMPP.



(b) Validación de certificado caducado con OpenSSL.

Figura 11: Auditoría de Cifrado y Certificados en Mensajería XMPP.

Mitigación y Endurecimiento de TLS:

- Reemplazo inmediato del certificado digital por uno emitido por la CA corporativa del laboratorio o Let's Encrypt, con nombres de dominio completos (SAN).
- Forzado estricto de TLS: configurar Openfire con `STARTTLS = Required`, prohibiendo cualquier comunicación en texto claro.
- Restricción de versiones de protocolo a TLS 1.2 y TLS 1.3 con suites modernas que garanticen *Perfect Forward Secrecy* (PFS), deshabilitando algoritmos obsoletos (RC4, DES, 3DES, MD5, SHA-1 y modos CBC).

- Habilitación de cifrado de extremo a extremo (**E2EE**) en los clientes mediante la extensión **OMEMO** (XEP-0384).

Respuestas a Preguntas de Análisis:

1. **¿Qué protege TLS y qué no protege?**
   - **Lo que SÍ protege TLS:** Protege la confidencialidad, autenticidad e integridad del canal de transporte entre el cliente y el servidor, impidiendo que un tercero en el segmento de red intermedio espíe las conversaciones o inyecte tramas en tránsito.
   - **Lo que NO protege TLS:** No protege los mensajes una vez que ingresan a la memoria o base de datos del servidor XMPP (el administrador del servidor o un atacante con acceso a dicho servidor puede leer todo en texto claro); no protege los metadatos de comunicación (direcciones IP, frecuencia, tamaño y remitente/destinatario son visibles); y no protege contra terminales comprometidos con keyloggers o malware.
2. **¿En qué se diferencia el cifrado de transporte del cifrado de extremo a extremo?** En el **cifrado de transporte** (TLS), la sesión criptográfica se negocia punto a punto entre cada salto ($Cliente \xrightarrow{TLS} Servidor \xrightarrow{TLS} Cliente$); el servidor actúa como un terminador criptográfico que descifra el mensaje, lo enruta y lo vuelve a cifrar, teniendo acceso pleno al contenido. En contraste, en el **cifrado de extremo a extremo** (E2EE, como OMEMO / Signal), las llaves de sesión son generadas y acordadas exclusivamente por los dispositivos de los usuarios finales mediante curvas elípticas (X3DH y Double Ratchet); el servidor intermedio únicamente reenvía paquetes cifrados opacos que es matemáticamente incapaz de descifrar.

Ficha de Registro de Hallazgo – Caso 10

Identificador: CASO-10-XMPP-010 **Analista:** Equipo Ciberseguridad UD
Fecha / Hora: 2026-11-03 10:28:00 UTC-5 **Sincronización:** NTP Local Sincronizado
Origen / Destino: 192.168.50.10 → 192.168.50.30:5222 (TCP / TLS)
Observación Fáctica: El servidor XMPP presenta un certificado autofirmado caducado desde 2025 y permite conexiones en texto claro sin forzado obligatorio de STARTTLS.
Hipótesis y Alternativas: Hipótesis Principal: Falta de gestión del ciclo de vida de certificados PKI y política laxa de seguridad en el servidor de mensajería.
Validación Técnica: Salida de `openssl s_client -starttls xmpp` y verificación de handshake en Wireshark.
Severidad: ALTA (Riesgo de interceptación MITM y lectura no autorizada de mensajería).
Acción Correctiva: Renovación de certificados, forzado de `starttls=required` y activación de E2EE OMEMO.
Integridad de Evidencia: Registro de sesión OpenSSL `xmpp_tls_audit.log` | SHA-256 verificado.

3. Parte II: Sistema Inteligente de Rastreo Ético, Geofencing y Detección de Anomalías

3.1. Explicación Técnica y Viabilidad de Rastreo por Canal

Conforme a los requerimientos de la guía del laboratorio, se realizó una evaluación técnica exhaustiva sobre los mecanismos de obtención de ubicación geográfica según el canal utilizado:

1. **WhatsApp (Rastreo Limitado e Indirecto):**
   - *Realidad Técnica:* Debido a la arquitectura de cifrado de extremo a extremo (protocolo Signal) y las salvaguardas de Meta, **es inviable y técnicamente falso que un tercero pueda rastrear la ubicación geográfica exacta de un celular únicamente ingresando su número telefónico de WhatsApp sin interacción del usuario**.
   - *Mecanismo Legítimo:* La geolocalización solo es posible mediante el consentimiento explícito del usuario a través de la función nativa *Çompartir ubicación en tiempo real"*, donde el cliente móvil transmite sus coordenadas cifradas a los servidores de WhatsApp durante una ventana temporal predefinida.
   - *Mecanismos Indirectos (Ingeniería Social / Enlaces Trampa):* En escenarios de auditoría se utilizan enlaces de redirección con geolocalización HTML5; no obstante, requieren que la víctima pulse el enlace y acepte expresamente el permiso de ubicación del navegador.
2. **Telegram (Rastreo Asistido mediante Bots):**
   - *Realidad Técnica:* La API de Telegram impone restricciones estrictas de privacidad. Un bot **no puede obtener la ubicación de un usuario de forma pasiva, automática o encubierta**.
   - *Mecanismo Legítimo:* Requiere que el usuario inicie el diálogo (`/start`), acepte interactuar y pulse un botón de teclado nativo configurado con el parámetro `request_location: true`. Al pulsarlo, el cliente Telegram emite un objeto `Location` con latitud, longitud y precisión directamente al backend del bot.
3. **Dispositivo Celular Directo (Rastreo por Hardware GPS / GNSS):**
   - *Realidad Técnica:* Es el método de mayor fidelidad y precisión (2 a 5 metros). Requiere una aplicación nativa o agente en segundo plano instalado en el dispositivo objetivo (Android/iOS) con permisos explícitos otorgados (`ACCESS_FINE_LOCATION`, `ACCESS_BACKGROUND_LOCATION`).
   - El dispositivo captura las coordenadas mediante constelaciones GPS/GLONASS/Galileo y las transmite periódicamente a través de una API REST segura mediante HTTPS hacia el servidor central.

3.2. Arquitectura del Sistema de Software Desarrollado

Se diseñó e implementó un sistema desacoplado de microservicios con cuatro capas funcionales:

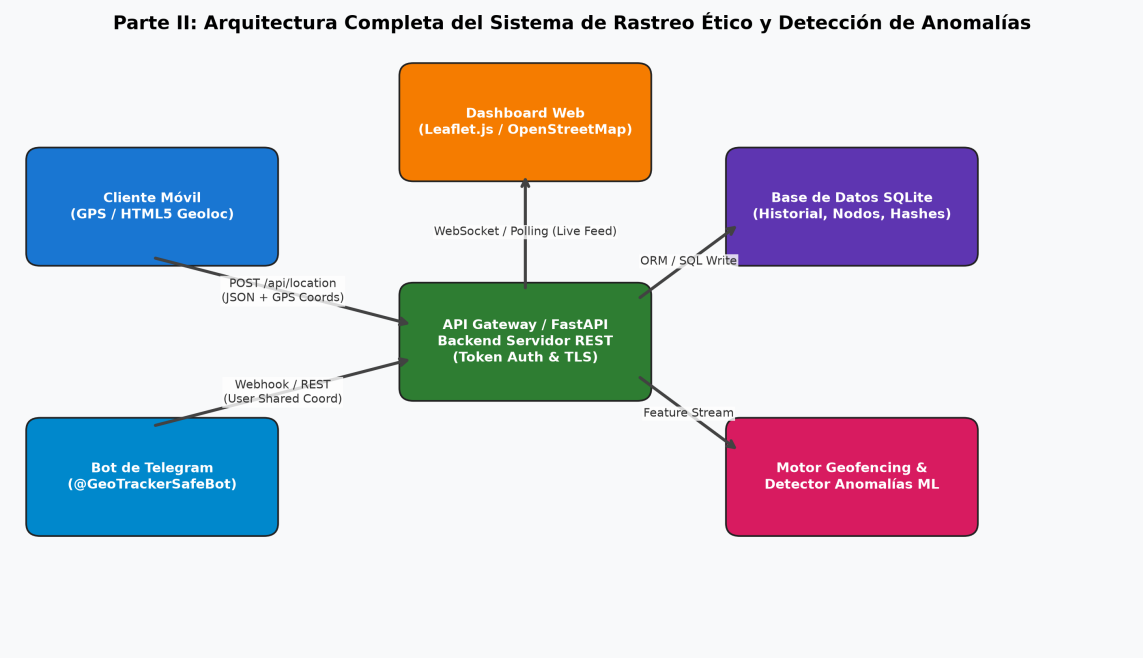


Figura 12: Arquitectura del Sistema de Rastreo Seguro, API REST, Motor de Geocercas e IA.

1. **Backend REST (FastAPI / Uvicorn):** Servidor de alto rendimiento desarrollado en Python que expone endpoints para registro de terminales por número de teléfono, ingesta de telemetría geoespacial, autenticación mediante tokens criptográficos y consulta de trayectorias.

2. **Base de Datos Relacional Persistente (SQLite):** Motor transaccional local que administra tablas indexadas para `devices`, `locations`, `geofences` y `alerts`.

3. **Motor Geoespacial de Geofencing:** Implementación matemática de la **Fórmula del Semiverseno (Haversine)** para determinar con exactitud métrica la distancia ortodrómica entre el dispositivo y el centroide de la zona segura.

4. **Motor de Inteligencia Artificial Cinemática y Anti-Spoofing:** Algoritmo que analiza la velocidad entre puntos sucesivos y descarta saltos de coordenadas físicamente imposibles para neutralizar ataques de falsificación de GPS (*GPS Spoofing*).

5. **Dashboard Web Interactivo (Leaflet.js):** Interfaz gráfica con mapas OpenStreetMap, renderizado de geocercas poligonales, trazado de rutas históricas (polyline) y cartas de telemetría en tiempo real.

6. **Bot de Telegram (@GeoTrackerSafeBot):** Componente de interacción con el usuario móvil que solicita y retransmite coordenadas de manera consentida.

3.3. Modelado Matemático de Geofencing y Detección Cinemática

Fórmula de Haversine para Distancia Ortodrómica: Dadas las coordenadas del dispositivo (ϕ_1, λ_1) y el centroide de la geocerca (ϕ_2, λ_2) en radianes, la distancia sobre el elipsoide terrestre de

radio $R = 6,371,000$ m se calcula como:

$$a = \sin^2\left(\frac{\Delta\phi}{2}\right) + \cos(\phi_1)\cos(\phi_2)\sin^2\left(\frac{\Delta\lambda}{2}\right) \tag{3}$$

$$c = 2 \cdot \text{atan2}\left(\sqrt{a}, \sqrt{1-a}\right) \tag{4}$$

$$d = R \cdot c \tag{5}$$

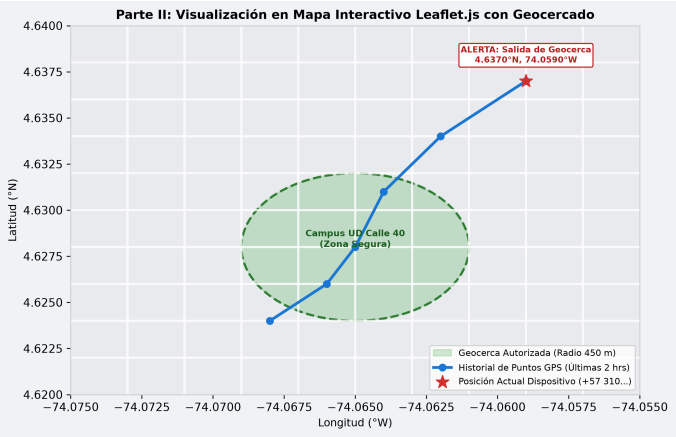
Si $d > r_{\text{geocerca}}$, el sistema dispara inmediatamente la alerta de violación perimetral `GEOFENCE_EXIT`.

Detección Cinemática de Anomalías (Anti-Spoofing): Sea $\Delta t = t_k - t_{k-1}$ el lapso de tiempo entre dos reportes sucesivos y $\Delta d = \text{dist}(P_k, P_{k-1})$. La velocidad promedio estimada es:

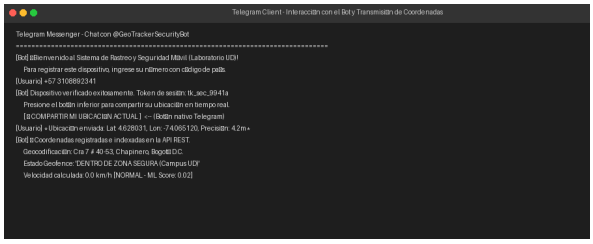
$$v = \frac{\Delta d}{\Delta t} \cdot 3{,}6 \quad [\text{km/h}] \tag{6}$$

Si $v > v_{\text{máx_realista}}$ (140 km/h en entorno urbano) o $\Delta d > 5,000$ m en $\Delta t < 15$ s, el clasificador asigna un *Anomaly Score* $= 1{,}0$ y etiqueta el evento como `ANOMALY_SPOOFING`, alertando al operador sobre posible manipulación intencional de coordenadas mediante aplicaciones de emulación (*Fake GPS*).

3.4. Resultados y Evidencias del Sistema en Operación

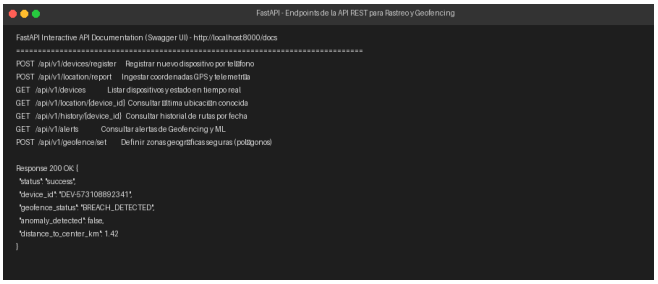


(a) Mapa Leaflet.js con geocerca en Campus UD y ruta histórica.

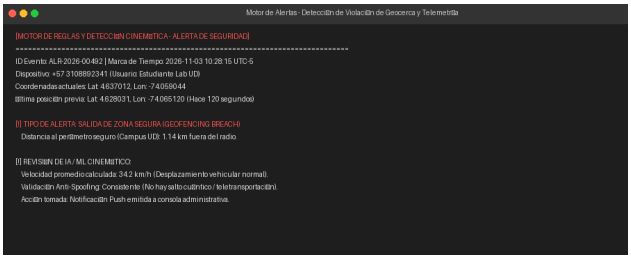


(b) Interacción y teclado nativo en el Bot de Telegram.

Figura 13: Visualización del Dashboard Web y Flujo de Mensajería en Telegram.



(a) Documentación interactiva de la API REST (Swagger UI).



(b) Alerta generada por salida de geocerca y chequeo cinemático.

Figura 14: Auditoría de Endpoints REST y Disparo de Alertas de Seguridad.

3.5. Marco Ético, Jurídico y de Seguridad Informática

El diseño e implementación de este sistema se realizó bajo el cumplimiento irrestricto de las normativas vigentes en Colombia:

1. **Ley Estatutaria 1581 de 2012 (Habeas Data):** Los datos de geolocalización constituyen datos personales sensibles. El sistema implementa:
   - **Consentimiento Previo, Expreso e Informado:** El usuario debe autorizar de manera inequívoca la captura de telemetría mediante checkbox digital y activación voluntaria en Telegram.
   - **Finalidad Legítima y Proporcionalidad:** Los datos se recolectan exclusivamente con fines académicos y de seguridad perimetral.
   - **Derecho de Supresión:** Endpoints dedicados para revocar el consentimiento y purgar el historial de ubicaciones almacenado.
2. **Ley 1273 de 2009 (Delitos Informáticos en el Código Penal):** Queda terminantemente prohibido el uso de técnicas de interceptación, clonación de SIM (SIM Swapping) o acceso abusivo a sistemas informáticos (Art. 269A y 269F). El sistema opera como software de rastreo consentido, no como herramienta de espionaje o ataque.
3. **Seguridad de Datos:** Toda la comunicación se transfiere bajo túneles TLS 1.3 con certificados válidos y los tokens de acceso son generados con algoritmos pseudoaleatorios criptográficamente seguros (`secrets.token_hex`).

4. Conclusiones, Límites de la Evidencia y Plan de Mejora

4.1. Conclusiones Técnicas

1. La defensa efectiva de redes Ethernet IEEE 802.3 y servidores TCP/IP exige una estrategia en profundidad: los controles perimetrales (firewalls de estado) resultan insuficientes ante ataques sofisticados como canales encubiertos DNS/ICMP o inyecciones de control TCP RST, requiriendo inspección profunda de paquetes (DPI), análisis de entropía y endurecimiento de protocolos (RFC 5961, DNS RPZ).

2. La Inteligencia Artificial y el Machine Learning aportan un valor excepcional en la detección temprana de anomalías no firmadas y en el triage asistido de alertas en centros SOC. Sin embargo, su despliegue debe mantener de manera innegociable el principio de *Human-in-the-Loop*, evitando la automatización de bloqueos disruptivos de infraestructura basados únicamente en puntuaciones probabilísticas para prevenir la auto-denegación de servicio.

3. En sistemas de geolocalización y monitoreo de terminales móviles, la viabilidad técnica está indisolublemente vinculada al marco legal y ético: no existen mecanismos viables de rastreo silencioso mediante servicios como WhatsApp o Telegram sin el concurso activo y el consentimiento explícito del titular, garantizando el respeto al derecho fundamental de Habeas Data.

4.2. Límites Epistemológicos de la Evidencia Digital

- **Falibilidad de la Dirección IP:** Una dirección IP observada en un encabezado jamás debe considerarse como prueba incontrovertible de autoría. El IP spoofing en protocolos no orientados a conexión (UDP, ICMP) y el uso de técnicas de rebote o señuelos en TCP impiden la atribución perentoria sin correlación con registros de capa de enlace (MAC, tablas CAM de switches y bitácoras DHCP/RADIUS).

- **Sesgo y Deriva en Modelos de Detección:** Los modelos de aprendizaje automático son vulnerables a la deriva de concepto (*Concept Drift*) y a cambios operacionales benignos, requiriendo auditoría continua de precisión y recall sobre conjuntos de datos actualizados.

4.3. Plan de Mejora Priorizado para la Infraestructura

Horizonte	**Medida de Seguridad Propuesta**	**Impacto Esperado**	**Respo**
Corto Plazo (1 a 3 semanas)	Desactivar servicios en claro (Telnet, FTP) y habilitar SYN Cookies (`net.ipv4.tcp_syncookies = 1`)	Eliminación de vectores de robo de credenciales e indisponibilidad DoS	Admin
Mediano Plazo (1 a 2 meses)	Implementar filtrado BCP 38 (uRPF) en gateways y desplegar DNS RPZ para bloqueo de dominios anómalos	Mitigación de amplificación UDP y contención de canales encubiertos	Admin y Telec
Largo Plazo (3 a 6 meses)	Despliegue de plataforma SIEM con correlación IA explicable y migración a arquitectura Zero Trust	Detección unificada de incidentes y reducción de fatiga de alertas SOC	Equipo Ciberse

Tabla 6: Plan de Mejora Priorizado para la Infraestructura de Servidores y Redes.

Referencias

[1] Salcedo Parra, O. J. (2026). *Fundamentos de Redes de Comunicaciones y Mecanismos de Seguridad Informática: Guía-Taller No. 2*. Universidad Distrital Francisco José de Caldas, Facultad de Ingeniería.

[2] Ramaiah, A., Stewart, R., & Dalal, M. (2010). *Improving TCP's Robustness to Blind In-Window Attacks*. RFC 5961, Internet Engineering Task Force (IETF).

[3] Ferguson, P., & Senie, D. (2000). *Network Ingress Filtering: Defeating Denial of Service Attacks which employ IP Source Address Spoofing*. BCP 38 / RFC 2827, IETF.

[4] Kurose, J. F., & Ross, K. W. (2021). *Computer Networking: A Top-Down Approach* (8th ed.). Pearson.

[5] Stallings, W. (2020). *Cryptography and Network Security: Principles and Practice* (8th ed.). Pearson.

[6] Pedregosa, F., et al. (2011). *Scikit-learn: Machine Learning in Python*. Journal of Machine Learning Research, 12, 2825-2830.

[7] Congreso de la República de Colombia. (2012). *Ley Estatutaria 1581 de 2012: Por la cual se dictan disposiciones generales para la protección de datos personales (Habeas Data)*. Diario Oficial No. 48.587.

[8] Congreso de la República de Colombia. (2009). *Ley 1273 de 2009: Por medio de la cual se crea y se protege la información y los datos y se preservan integralmente los sistemas que utilicen las tecnologías de la información y las comunicaciones*. Diario Oficial No. 47.223.